

Atum Solana Programs Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Farouk

Al-Qa'qa'

August 29, 2025

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 3

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 4

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Atum Labs on Atum Solana Programs. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated August 29, 2025, was delivered to Atum Labs, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Atum Labs or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 4 days, the Cyfrin team conducted an audit on the Atum Solana Programs code provided by Atum Labs. The findings consist of 1 Critical, 2 Medium & 2 Low severity issues with the remainder being informational.

Summary

Project Name	Atum Solana Programs
Repository	solana-escrow
Commit	6fdbde50f1b1...
Audit Timeline	Aug 26th - Aug 29th, 2025
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	1	1	0
High Risk	0	0	0
Medium Risk	2	2	0
Low Risk	2	2	0
Informational	3	3	0
Gas Optimizations	0	0	0
Total	8	8	0

6 Audit Scope

Cyfrin conducted an audit of the Atum Solana programs based on the code present in the repository commit hash 6fdbde5. The following files construct the scope of the audit:

```
programs/escrow/src/constants.rs
programs/escrow/src/errors.rs
programs/escrow/src/events.rs
programs/escrow/src/instructions/delegate.rs
programs/escrow/src/instructions/escrow.rs
programs/escrow/src/instructions/mod.rs
programs/escrow/src/lib.rs
programs/escrow/src/state.rs
programs/escrow/src/utils/mod.rs
programs/escrow/src/utils/replay.rs
programs/escrow/src/utils/signatures.rs
programs/fulfillment_proxy/src/lib.rs
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

Solana Escrow is a PDA-owned escrow that moves SPL tokens under off-chain Ed25519 authorization. A companion Fulfillment Proxy emits settlement events. The flow is deposit → reserve → release or refund.

- **State**: `DepositInfo` records a deposit (depositor, mint, amount and recipient) and owns the escrow ATA. `ReplayBucket` tracks used deposit nonces.
- **Dependencies**: the Ed25519 program and the instructions sysvar for signature verification, and SPL Token and Associated Token for token accounts and transfers.
- **Core instructions**:
  - `deposit` creates a `DepositInfo` and its escrow ATA and transfers the deposited tokens to the escrow ATA.
  - `reserve` sets the recipient of a deposit.
  - `release` transfers the net amount to the recipient, and `refund` returns the amount to the depositor; both close the escrow ATA and `DepositInfo`.
  - `fulfill` / `strict_fulfill` (Fulfillment Proxy) perform a token transfer that emits a settlement event.

9 Attestation

Cyfrin attests that it performed a security review of the Atum Solana Programs code provided by Atum Labs.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2025-08-29-cyfrin-atum-solana-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Atum Labs has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=7137473a3fcb6519fcee863e0d0ca4a88957f059a854888feb98ab6738300f40
F=2025-08-29-cyfrin-atum-solana-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.